

Security Testing

Security testing is a type of testing that undergo vulnerabilities in the system and protect it from malicious programs and intruders. It ensures:

Types:

1. Vulnerability Scanning: It is a type of testing that uses automated tools to scan the system for known vulnerabilities and weaknesses.

2. Security Scanning: It involves identifying weaknesses in the network or system and then providing solutions to mitigate these risks.

3. Penetration Testing: It simulates an attack from a malicious hacker to identify vulnerabilities in the system.

4. Risk Assessment: It involves analyzing the security risks that could affect the organization. Risks are categorized as low, medium, or high, and this testing suggests controls and measures to minimize those risks.

5. Security Auditing: Security audits ensure that all security standards and protocols are being followed and identify any gaps that need to be addressed.

6. Ethical Hacking: It also known as white-hat hacking, is when security professionals are hired to simulate attacks on the system to identify vulnerabilities.

7. Posture Assessment: These will combines security scanning, ethical hacking, and risk assessments to provide an overall view of the system's security.

8. Application Security Testing: These Testing focuses specifically on identifying vulnerabilities within the application itself.

9. Network Security Testing: In these testing targets the vulnerabilities in the network infrastructure, such as firewalls, routers, and other network devices. This testing is crucial for identifying weaknesses that could allow unauthorized access to the system.

10. Social Engineering Testing: Social Engineering Testing simulates phishing, baiting, or other manipulative techniques used to exploit human behavior to gain unauthorized access.

Importance:

Role of QA in Security Testing

- **Security Awareness:** Knowing common web vulnerabilities.
- **Input Validation Testing:** Trying invalid or malicious data inputs.
- **Boundary Testing:** Checking system behavior with edge cases (long input, special characters).
- **Authentication Testing:** Trying weak passwords, blank credentials, expired sessions.
- **Error Message Handling:** Ensure system doesn't reveal internal logic (like SQL errors).

- **Data Protection Checks:** Confirm sensitive data is hidden (no plain text passwords).
- **Reporting:** Report suspicious findings to security lead or mentor (not exploit them).